

Política de Segurança da Informação - OrganizaAí

Data da Elaboração: 04 de maio de 2026

Versão: 1.0

****Responsável:** Diogo Mendes Baptista e Lucas do Nascimento Lima

1. Introdução

Esta Política de Segurança da Informação (PSI) estabelece as diretrizes e os princípios para a proteção dos ativos de informação do sistema OrganizaAí, uma API RESTful de gestão de eventos. Nosso objetivo é garantir a confidencialidade, integridade e disponibilidade das informações, em conformidade com as melhores práticas de segurança e as exigências legais e regulatórias, como a Lei Geral de Proteção de Dados (LGPD).

Esta política se aplica a todos os usuários, desenvolvedores e quaisquer outras partes que interajam com o sistema OrganizaAí e seus dados.

2. Objetivos da Política de Segurança da Informação

Os principais objetivos desta PSI são:

- Proteger os dados pessoais e informações sensíveis contra acessos não autorizados, uso indevido, alteração, destruição ou divulgação.
- Garantir a continuidade dos serviços do OrganizaAí, minimizando o impacto de incidentes de segurança.
- Assegurar a conformidade com as leis e regulamentações aplicáveis à proteção de dados e segurança da informação.
- Promover a conscientização e a responsabilidade de todos os envolvidos no uso e desenvolvimento do sistema em relação à segurança da informação.

3. Ativos de Informação Abrangidos

Esta política abrange todos os ativos de informação relacionados ao OrganizaAí, incluindo, mas não se limitando a:

- Dados pessoais de usuários (nome, e-mail, senhas).
- Dados de eventos (descrições, datas, participantes, insumos, custos).
- Código-fonte da aplicação.

- Bancos de dados.
- Servidores e infraestrutura de rede.
- Documentações e registros.

4. Princípios de Segurança da Informação

O OrganizaAí adota os seguintes princípios fundamentais de segurança:

- **Confidencialidade:** Garantir que a informação seja acessível apenas por pessoas autorizadas.
- **Integridade:** Assegurar que a informação seja precisa e completa, e que não tenha sido modificada sem autorização.
- **Disponibilidade:** Garantir que os usuários autorizados tenham acesso à informação e aos ativos correspondentes quando necessário.
- **Autenticidade:** Verificar a identidade de usuários e a origem das informações.
- **Não Repúdio:** Garantir que as ações realizadas não possam ser negadas posteriormente.

5. Controles de Segurança Implementados

Com base na análise do projeto OrganizaAí, os seguintes controles de segurança são implementados:

5.1. Segurança de Acesso e Autenticação

- **Criptografia de Senhas (BCrypt):** Todas as senhas de usuários são armazenadas utilizando o algoritmo BCrypt com um fator de custo (Work Factor) configurado para 12. O BCrypt gera automaticamente um Salt criptográfico único para cada usuário, protegendo contra ataques de força bruta e rainbow tables.
- **Autenticação de Dois Fatores (2FA/TOTP):** Implementação do padrão TOTP (Time-based One-Time Password) via Google Authenticator (RFC 6238), adicionando uma camada de segurança física e protegendo contra ataques de SIM Swapping.
- **Gestão de Sessões via JWT (Stateless):** Utilização de JSON Web Tokens (JWT) assinados com algoritmo HMAC-SHA384. Os tokens possuem tempo de expiração curto para limitar a janela de oportunidade em caso de interceptação.
- **Invalidação de Sessão (Logout Blacklist):** Implementação de uma tabela de Blacklist no banco de dados para tokens revogados, garantindo que o logout seja respeitado

instantaneamente.

- **Proteção contra Força Bruta:** Política de bloqueio temporário após 5 tentativas falhas, com atraso exponencial e bloqueio de 15 minutos para prevenir ataques automatizados de preenchimento de credenciais.
- **Controle de Acesso Baseado em Função (RBAC):** Diferenciação de níveis de acesso entre organizadores e participantes, garantindo que cada usuário tenha acesso apenas às funcionalidades e dados necessários para suas atribuições.

5.2. Segurança da Aplicação

- **Desenvolvimento Seguro (Security by Design):** A segurança é considerada desde as fases iniciais de concepção e desenvolvimento do sistema, incorporando práticas de codificação segura e revisão de código.
- **Validação de Entradas:** Todas as entradas de usuários são validadas para prevenir ataques como Injeção SQL, Cross-Site Scripting (XSS) e outros.
- **Tratamento de Erros:** Mensagens de erro são genéricas e não expõem informações sensíveis do sistema.
- **Atualizações de Dependências:** Manutenção regular das dependências do projeto para garantir que vulnerabilidades conhecidas sejam corrigidas.

5.3. Segurança de Dados

- **Criptografia em Repouso e em Trânsito:** Dados sensíveis são criptografados tanto em repouso (no banco de dados) quanto em trânsito (durante a comunicação entre cliente e servidor).
- **Backup e Recuperação:** Implementação de rotinas de backup regulares e planos de recuperação de desastres para garantir a disponibilidade e integridade dos dados em caso de falhas.
- **Anonimização e Pseudonimização:** Quando aplicável e viável, dados pessoais são anonimizados ou pseudonimizados para reduzir riscos de privacidade.

5.4. Monitoramento e Resposta a Incidentes

- **Monitoramento de Logs:** Registro detalhado de atividades do sistema e de segurança para detecção de anomalias e auditoria.
- **Plano de Resposta a Incidentes:** Definição de procedimentos para identificar, analisar, conter, erradicar e recuperar-se de incidentes de segurança.
- **Testes de Segurança:** Realização periódica de testes de penetração e varreduras de vulnerabilidades para identificar e corrigir falhas de segurança.

6. Responsabilidades

- **Desenvolvedores:** São responsáveis por implementar as diretrizes de segurança no código, seguir as melhores práticas de desenvolvimento seguro e participar de treinamentos de segurança.
- **Administradores do Sistema:** São responsáveis por configurar e manter a infraestrutura de forma segura, monitorar logs e responder a incidentes de segurança.
- **Usuários:** São responsáveis por proteger suas credenciais de acesso, utilizar senhas fortes, habilitar 2FA e reportar qualquer atividade suspeita.

7. Treinamento e Conscientização

Todos os envolvidos no desenvolvimento e operação do OrganizaAí devem receber treinamento e conscientização sobre as políticas e procedimentos de segurança da informação, bem como sobre as melhores práticas de proteção de dados.

8. Revisão da Política

Esta Política de Segurança da Informação será revisada anualmente ou sempre que houver mudanças significativas na legislação, tecnologia ou nos processos do OrganizaAí, para garantir sua contínua adequação e eficácia.

9. Contato

Para quaisquer dúvidas ou informações adicionais sobre esta Política de Segurança da Informação, entre em contato através dos canais de suporte do OrganizaAí.

10. Histórico de Revisões

Versão	Data	Descrição da Alteração	Autor
1.0	04/05/2026	Elaboração inicial do documento.	Manus AI